Lecture Notes S08: Mô phỏng Tấn công & Phòng thủ Hạ tầng PKI (AD CS, Rogue CA, MitM)

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Phân loại 13 Lỗ hổng Cấu hình Mẫu Chứng thư (ESC1 đến ESC13)

Các nghiên cứu an ninh mạng hiện đại chỉ ra các kịch bản khai thác phổ biến: * **ESC1:** Mẫu cấp quyền xác thực Client cho phép người dùng tự chỉ định SAN. * **ESC2:** Mẫu có EKU rỗng hoặc Any Purpose, cho phép dùng vào bất kỳ mục đích gì. * **ESC3:** Mẫu có EKU Certificate Request Agent, cho phép ký đại diện để xin chứng chỉ cho tài khoản khác. * **ESC4:** Phân quyền ACL trên mẫu cho phép tài khoản thường chỉnh sửa cấu hình của mẫu. * **ESC8:** Dịch vụ Web Enrollment hỗ trợ HTTP NTLM không an toàn, dễ bị tấn công tiếp sóng xác thực.

---

2. Kỹ thuật Rà soát Tự động với Certify và Certipy

Học viên sử dụng các công cụ chuyên dụng để quét và phát hiện các mẫu chứng thư có cấu hình nguy hiểm trong hệ thống:

```
# Quét tìm các mẫu chứng thư dễ bị tấn công (Vulnerable Templates)
certipy find -u user@kma.internal -p 'Password123' -dc-ip 192.168.1.10 -vulnerable

# Kiểm tra phân quyền ACL trên CA
certipy find -u user@kma.internal -p 'Password123' -dc-ip 192.168.1.10 -enabled
```

---

3. Tài liệu Tham khảo Mở rộng

1. **SpecterOps Research: Certified Pre-Owned.**
2. **Certipy GitHub Repository:** github.com/ly4k/Certipy
3. **GhostPack Certify:** github.com/GhostPack/Certify